

Security+ 4.5 · Firewalls

Mestre CyberSec · Aula 4.5 — Firewalls (11:31) · [Assistir Vídeo no YouTube](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: NGFW: aplicação-aware (vê o tráfego por app); user-aware; threat intel integrado; SSL inspection. UTM = tudo em 1 (pequena empresa). Screened subnet (DMZ) = zona entre internet e interno. Firewall rules: allow/deny/port/protocol/IP.

💡 Highlights que a prova CompTIA cobra

- NGFW = stateful + app + user + threat intelligence
- Screened subnet (DMZ): zona entre a internet e a rede interna

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'firewall that inspects traffic at the application layer'=NGFW/WAF

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Firewall de Próxima Geração (NGFW)

Firewall que adiciona reconhecimento de aplicação, reconhecimento de usuário, inteligência de ameaças integrada e inspeção SSL/TLS além da filtragem stateful tradicional.

⚠ **Armadilha CompTIA:** Gatilho: 'inspeciona tráfego na camada de aplicação' ou 'identifica aplicativos/usuários' = NGFW. Distinção: WAF é focado em HTTP/HTTPS e ataques web.

• Gerenciamento Unificado de Ameaças (UTM)

Appliance de segurança tudo-em-um que combina firewall, IDS/IPS, antivírus, VPN, filtragem de conteúdo e outros controles, geralmente para pequenas ou médias empresas.

⚠ **Armadilha CompTIA:** Gatilho: 'tudo em um' para pequena empresa = UTM. Distinção: NGFW é mais focado em app/user/threat intelligence, não necessariamente um pacote UTM completo.

• Sub-rede Filtrada (DMZ)

Zona de rede entre a Internet e a rede interna que hospeda serviços públicos, isolando-os da LAN interna.

⚠ **Armadilha CompTIA:** Gatilho: 'zona entre a Internet e a rede interna' ou 'DMZ' = screened subnet. Distinção: não é a LAN interna; é uma área intermediária controlada.

• Firewall Stateful (N/A)

Firewall que rastreia conexões ativas usando uma tabela de estados e permite tráfego de retorno para sessões estabelecidas.

⚠ **Armadilha CompTIA:** Gatilho: 'lembra do estado da conexão' = stateful. Distinção: não confunda com stateless, que analisa cada pacote isoladamente.

• Firewall Stateless (N/A)

Firewall que filtra cada pacote independentemente usando regras estáticas ou ACLs sem rastrear o estado da conexão.

⚠ **Armadilha CompTIA:** Gatilho: 'filtragem de pacotes sem estado' ou 'ACL simples' = stateless. Distinção: mais rápido, porém menos seguro que stateful.

• Firewall de Aplicação Web (WAF)

Firewall que inspeciona tráfego HTTP/HTTPS para proteger aplicações web de ataques da Camada 7, como SQL injection e XSS.

⚠ **Armadilha CompTIA:** Gatilho: ataques a aplicações web / HTTP/HTTPS = WAF. Distinção: se o enunciado fala de camada de aplicação genérica/app-aware, pode ser NGFW.

• Inspeção SSL/TLS

Processo em que um firewall descriptografa, inspeciona e recriptografa tráfego SSL/TLS para detectar ameaças escondidas em sessões criptografadas.

⚠ **Armadilha CompTIA:** Gatilho: 'inspeção de tráfego criptografado' é recurso do NGFW. Distinção: exige certificado de CA interna e pode gerar preocupações de privacidade.

• Regras de Firewall (ACL)

Regras ordenadas de permitir/negar que especificam IP de origem/destino, porta, protocolo e ação, avaliadas de cima para baixo pelo firewall.

⚠ **Armadilha CompTIA:** Gatilho: a primeira regra correspondente vence; há regra implícita deny all no final. Distinção: ordem incorreta causa bloqueio ou permissão indevida.

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa de varejo deseja aplicar uma política em que apenas o grupo de vendas possa usar um CRM em nuvem específico, embora os funcionários também acessem muitos outros sites HTTPS na porta TCP 443. A equipe de segurança precisa identificar o tráfego por aplicativo e por identidade do usuário, em vez de apenas por endereço IP e porta. Que tipo de firewall deve ser implantado?

- A) Firewall de filtragem de pacotes sem estado
- B) Firewall de aplicação web
- C) Firewall de próxima geração
- D) Firewall com estado com ACLs baseadas em porta

QUESTÃO 2 · CENÁRIO DE EXAME

Um consultório odontológico pequeno tem uma única conexão de internet e um orçamento limitado de TI. Ele precisa de um único dispositivo que forneça filtragem de firewall, verificação antivírus, prevenção de intrusões e filtragem de conteúdo web. Qual solução melhor atende a esses requisitos?

- A) Firewall de próxima geração limitado à conscientização de aplicativos
- B) Dispositivo de gerenciamento unificado de ameaças
- C) Firewall de aplicação web
- D) Sub-rede filtrada com um firewall com estado

QUESTÃO 3 · CENÁRIO DE EXAME

Uma empresa hospeda um servidor web voltado para a internet. Os requisitos de segurança determinam que usuários da internet devem alcançá-lo na porta TCP 443, mas, se o servidor for comprometido, ele não deve conseguir iniciar conexões diretas com a rede interna de banco de dados. Onde o servidor web deve ser colocado?

- A) Na VLAN interna de usuários
- B) Em uma sub-rede filtrada
- C) Na VLAN de gerenciamento
- D) Na mesma sub-rede do servidor de banco de dados

QUESTÃO 4 · CENÁRIO DE EXAME

Os administradores desejam permitir que usuários internos iniciem sessões HTTPS para sites da internet e que o firewall permita automaticamente o tráfego de retorno. Eles também querem que o firewall rastreie conexões ativas e tome decisões com base no estado da sessão. Qual comportamento de firewall deve ser implementado?

- A) Filtragem de pacotes sem estado
- B) Inspeção com estado
- C) Filtragem de aplicação web
- D) Somente tradução de endereços de rede

QUESTÃO 5 · CENÁRIO DE EXAME

Uma ACL de roteador legado permite entrada na porta TCP 80 para um servidor web interno. Os usuários conseguem alcançar o servidor, mas as respostas do servidor são descartadas a menos que uma regra de saída também seja adicionada. Que tipo de firewall está sendo descrito?

- A) Firewall de inspeção com estado
- B) Firewall de filtragem de pacotes sem estado
- C) Firewall de próxima geração
- D) Firewall de aplicação web

QUESTÃO 6 · CENÁRIO DE EXAME

Um site de comércio eletrônico está recebendo tentativas de injeção de SQL e cross-site scripting em requisições HTTP. A equipe de segurança deseja bloquear esses ataques de camada de aplicação antes que cheguem ao servidor web. Qual controle é mais adequado para essa tarefa?

- A) Regra de firewall com estado
- B) Firewall de aplicação web
- C) Política de inspeção SSL/TLS
- D) Sub-rede filtrada

QUESTÃO 7 · CENÁRIO DE EXAME

O firewall de perímetro de uma empresa não consegue detectar malware dentro do tráfego HTTPS de saída porque o payload está criptografado. A segurança quer que o firewall descriptografe, inspecione e recriptografe o tráfego antes que ele chegue ao destino. Qual recurso deve ser habilitado?

- A) Validação DNSSEC
- B) Tradução de endereços de rede
- C) Inspeção SSL/TLS
- D) Filtragem de pacotes sem estado

QUESTÃO 8 · CENÁRIO DE EXAME

Um administrador de firewall deve permitir que apenas a sub-rede de contabilidade 10.20.30.0/24 alcance o servidor de folha de pagamento 10.20.40.10 pela porta TCP 443. Qual entrada de ACL segue o princípio do menor privilégio?

- A) permit tcp any any eq 443
- B) permit ip 10.20.30.0 0.0.0.255 any
- C) permit tcp 10.20.30.0 0.0.0.255 host 10.20.40.10 eq 443
- D) deny tcp any any eq 443

QUESTÃO 9 · CENÁRIO DE EXAME

Um firewall tem uma regra que permite que 10.0.0.50 alcance um banco de dados na porta TCP 1521, mas a regra foi colocada depois de uma regra que nega toda a sub-rede 10.0.0.0/24. O administrador do banco de dados relata que a conexão ainda está bloqueada. O que o administrador deve fazer primeiro?

- A) Mover a regra de permissão específica para cima da regra de negação da sub-rede
- B) Alterar a regra de permissão específica para permitir any any
- C) Desativar permanentemente a regra de negação da sub-rede
- D) Adicionar uma segunda regra de negação abaixo da regra de permissão

QUESTÃO 10 · CENÁRIO DE EXAME

A equipe de segurança quer que o firewall de perímetro bloqueie automaticamente endereços IP e domínios de um feed comercial de ameaças sem editar manualmente as ACLs todos os dias. Qual recurso de NGFW deve ser configurado?

- A) Integração com feed de inteligência de ameaças
- B) Inspeção SSL/TLS
- C) Política ciente de aplicativos
- D) Conscientização de identidade do usuário

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Firewall de próxima geração

Um firewall de próxima geração (NGFW) consegue identificar aplicativos independentemente da porta e aplicar regras com base na identidade do usuário ou do grupo. Um firewall sem estado ou com estado baseado em porta não consegue distinguir de forma confiável o CRM de outro tráfego HTTPS, e um WAF protege aplicações web em vez de aplicar políticas de acesso de usuário/aplicativo em toda a rede.

Questão 2: Alternativa B — Dispositivo de gerenciamento unificado de ameaças

Um dispositivo de gerenciamento unificado de ameaças (UTM) combina várias funções de segurança, como firewall, antivírus, IPS e filtragem de conteúdo, em um único dispositivo, o que é adequado para uma organização pequena com orçamento e equipe limitados. Um NGFW pode incluir alguns recursos, mas um UTM é posicionado especificamente como uma solução tudo em um; um WAF protege aplicações web e uma sub-rede filtrada é uma arquitetura, não um dispositivo de segurança tudo em um.

Questão 3: Alternativa B — Em uma sub-rede filtrada

Uma sub-rede filtrada, frequentemente chamada de DMZ, é uma zona de buffer entre a internet e a rede interna. Servidores públicos são colocados nela, e regras de firewall podem permitir entrada na porta 443 enquanto restringem o acesso de saída da DMZ para sistemas internos. VLANs internas, VLAN de gerenciamento e a sub-rede do banco de dados expõem indevidamente recursos internos se o servidor web for comprometido.

Questão 4: Alternativa B — Inspeção com estado

A inspeção com estado mantém uma tabela de estado das conexões ativas. Quando um usuário interno inicia uma sessão HTTPS de saída, o firewall pode permitir automaticamente os pacotes de retorno correspondentes sem uma regra de entrada separada. A filtragem sem estado avalia cada pacote independentemente e exigiria regras explícitas de retorno; WAF e NAT sozinhos não fornecem rastreamento de estado de conexão.

Questão 5: Alternativa B — Firewall de filtragem de pacotes sem estado

Um firewall de filtragem de pacotes sem estado avalia cada pacote em relação a regras estáticas e não rastreia sessões, portanto o tráfego de retorno deve ser explicitamente permitido por outra entrada de ACL. Firewalls com estado e de próxima geração rastreiam conexões e podem permitir o tráfego de retorno automaticamente; um WAF concentra-se em ataques de aplicação HTTP, não no comportamento básico de retorno de pacotes.

Questão 6: Alternativa B — Firewall de aplicação web

Um firewall de aplicação web (WAF) inspeciona requisições HTTP/HTTPS e pode detectar e bloquear ataques de camada de aplicação, como injeção de SQL e XSS. Um firewall com estado geralmente aplica conexões de camada de rede, a inspeção SSL/TLS descriptografa o tráfego para inspeção mas não é a lógica de bloqueio de ataques em si, e uma sub-rede filtrada é um desenho de segmentação de rede.

Questão 7: Alternativa C — Inspeção SSL/TLS

A inspeção SSL/TLS permite que o firewall atue como intermediário confiável, descriptografando o tráfego HTTPS de saída, inspecionando-o em busca de malware ou violações de política e recriptografando-o antes de encaminhá-lo. DNSSEC valida respostas DNS, NAT traduz endereços e a filtragem sem estado não consegue inspecionar payloads de aplicação criptografados.

Questão 8: Alternativa C — permit tcp 10.20.30.0 0.0.0.255 host 10.20.40.10 eq 443

A regra deve especificar a sub-rede de origem, o host de destino, o protocolo e a porta de destino para que apenas o tráfego necessário seja permitido. Permitir any any eq 443 permite demais, permitir IP da sub-rede para any permite todos os protocolos e destinos, e uma regra de negação sozinha não atenderia ao requisito.

Questão 9: Alternativa A — Mover a regra de permissão específica para cima da regra de negação da sub-rede

ACLs de firewall geralmente são processadas de cima para baixo e param na primeira correspondência. Se uma negação ampla para 10.0.0.0/24 aparecer antes da permissão específica para 10.0.0.50, a negação prevalece. A correção correta é mover a permissão específica para cima da negação ampla, preservando o menor privilégio. Tornar a permissão any any ou desativar a regra de negação criaria acesso excessivo, e adicionar outra negação não ajudaria.

Questão 10: Alternativa A — Integração com feed de inteligência de ameaças

A integração de inteligência de ameaças permite que um NGFW consuma feeds dinâmicos de IPs, domínios e URLs maliciosos e aplique bloqueios automaticamente. A inspeção SSL/TLS descriptografa tráfego, a política ciente de aplicativos controla aplicativos e a conscientização de identidade do usuário mapeia usuários para políticas; nenhum desses recursos, por si só, consome feeds de IP/domínio maliciosos automaticamente.